



OSINT ON YAHOO

Conducting an OSINT investigation on the Yahoo Breach



JULY 15, 2025
AYDEN ROMULUS

Table of Contents

Part A: OSINT Investigation	2
Introduction.....	2
Why Are Crown Jewels Significant?	2
What Are The Consequences If Compromised?	3
Crown Jewels of Yahoo’s Security Breach.....	3
Why did threat actors target these crown jewels of Yahoo?	4
OSINT Investigation	5
Organization’s Mission Statement and Values	5
Financial Information (Revenue, Expenses, Investments)	6
Marketing and Advertising Campaigns	7
Partnerships and Collaborations	8
Recent News Coverage (Press Releases, Articles, Interviews)	9
References	11
Part B: Phishing Email Exercise.....	16
Phishing Email Example	16
Social Engineering Tactics Used.....	17

Part A: OSINT Investigation

Introduction

In the context of cyber security, “crown jewels” are defined as the most valuable digital assets within an organization. They are vital to an organization’s long-term operation, reputation, and competitive advantage. These assets typically include sensitive personal information, customer data, intellectual property, critical databases, network systems, financial records, and proprietary technologies (Luckie, 2023; Ribeiro et al., 2024; Singh, 2020).

Why Are Crown Jewels Significant?

Crown jewels are critical because of:

- **Long-term Business Operation** – Since they are central to business procedures, their loss or interruption can put a stop to ongoing operations (OwlEye, 2024; Mile High Cyber, 2025).
- **Competitive Advantage** – These assets frequently contain expertise like trade secrets or intellectual property that provide a business with a competitive edge against others (Morgan Hill, 2022; OwlEye, 2024).
- **Regulatory Compliance** – Because crown jewels are regarded as most valuable, there are regulations and laws that require they be protected (Francisco, 2022; OwlEye, 2024).
- **Reputation** – Breaches can damage trust with customers, partners, and the public (Faulder, 2023; Mile High Cyber, 2025).

What Are The Consequences If Compromised?

Attackers often target these crown jewels because they hold the highest value and can yield high payoffs. If crown jewels are breached, the consequences can be severe:

- **Disruption of Operations** – Attacks have the potential to halt productivity or important services, causing downtime and lost income (Mile High Cyber, 2025; OwlEye, 2024).
- **Loss of Competitive Edge** – Exposure of trade secrets or business strategies can negatively affect the organization's position in the market (Faulder, 2023; Morgan Hill, 2022).
- **Legal and Regulatory Penalties** – Fines or legal action may follow a breach if regulated data was mishandled or not secured accordingly (Francisco, 2022; OwlEye, 2024).
- **Reputational Damage** – An organization's image may suffer long-term effects if there is a loss in trust from stakeholders and customers (Francisco, 2022; Morgan Hill, 2022).
- **Financial Loss** – Negative outcomes of a breach like theft, fraud and ransom demands can lead to significant losses as well as costly recovery efforts (Achterholt, 2025; Bagla, 2024; Faulder, 2023).

Crown Jewels of Yahoo's Security Breach

Yahoo is an American organization which offers several services, including Yahoo Mail, Yahoo News, Yahoo Finance, Yahoo Sports, and their well-known search engine, Yahoo Search. The organization continues to hold the record for the greatest number (over three billion) of affected individuals worldwide after suffering two of the largest data breaches ever reported in 2013 and 2014. It has been documented that threat actors were able to gain access to crown jewels such as usernames and email addresses, phone numbers, birth dates, hashed (MD5)

passwords, encrypted and unencrypted security questions and answers (Blassberger et al., 2018; StrongDM Team, 2025; Truță, 2017; Wikipedia Contributors, 2024).

Why did threat actors target these crown jewels of Yahoo?

1. Credential Abuse and Monetary Gain

- **Account Breaching:** With the acquisition of usernames, emails, hashed passwords, and security questions attackers can access Yahoo accounts as well as accounts on other platforms (banking, social media, and enterprise accounts) where credentials have been reused (Allstate Identity Protection, 2016; StrongDM Team, 2025).
- **Sale on Dark Web:** Sensitive information like this can be regarded as high value on the black-market and can attract threat actors like spammers, phishers, and identity thieves (Allstate Identity Protection, 2016; StrongDM Team, 2025).

2. Espionage and Intelligence Gathering

- **State-Sponsored Motivation:** There is evidence that shows that the breach was initiated by state-sponsored actors which may seek intelligence and have the capacity to target certain individuals for monitoring, blackmail or any other further attacks (Allstate Identity Protection, 2016; Perlroth, 2017; StrongDM Team, 2025).
- **Access to Email Content:** Attackers gained access to user's emails and sensitive data by stealing passwords and forging cookies. This would further their goals, making targets even more vulnerable and give attackers useful information (Logixal, 2016; StrongDM Team, 2025).

3. Targeted Phishing and Social Engineering

- In the documentation of the incident, details of breached security questions and answers were evident which may have given attackers leverage for experienced phishing schemes or to reset passwords on other platforms (StrongDM Team, 2025; Trend Micro, 2016; Truță, 2017).

In summary, the Yahoo breach provided attackers with an attractive amount of sensitive personal data, much of it due to poor encryption and security functions. It can be seen vividly why threat actors targeted their crown jewels. They exploited these known vulnerabilities to eventually satisfy their motivations of credential abuse and monetary gain, espionage and intelligence and targeted phishing and social engineering.

OSINT Investigation

Organization's Mission Statement and Values

The premise of Yahoo's mission statement is to use innovative media and technology to connect people to their passions, communities, and the world around them. Excellence, innovation, customer focus, teamwork, community, and fun are among the company's key principles. Yahoo places a significant value on user-driven product development empowering people, and providing customized experiences (CBM Team, 2025; JLP, 2005).

Malicious Use by Threat Actors

Threat actors can create highly sophisticated and convincing social engineering efforts to be aligned closely with Yahoo's values and branding. Copying the tone and language of Yahoo's mission can make messages more persuasive to users or employees.

Exploitation Example

Attackers can distribute emails that mimics Yahoo's dedication, like customer-focused "community updates," to deceive users into clicking malicious links for "upgrades" or "exclusive features" intended to steal login credentials.

Recommendations for Mitigation

To mitigate exploitation, the organization should regularly educate users and staff on social engineering techniques and brand impersonation. Yahoo should monitor fraudulent use of their branding closely online. They should implement email authentication controls like Domain-based Message Authentication, Reporting & Conformance (DMARC), Sender Policy Framework (SPF), and Domain Keys Identified Mail (DKIM). DMARC along with SPF and DKIM are utilized to prevent spoofing and phishing attacks by verifying the sender of an email and how to manage emails that fail verification.

Financial Information (Revenue, Expenses, Investments)

Yahoo experienced dwindling sales and financial difficulties, particularly before and during the security breaches. In one instance, a quarter in 2015 saw sales drop to \$1.04 billion due to higher advertising and product investment costs. Due to class-action settlements, fines, and a \$350 million drop in Yahoo's purchase price by Verizon, the 2013 – 2014 breaches caused losses of over \$232.5 million (CBS San Francisco, 2015; Mills, 2006; StrongDM Team, 2025).

Malicious Use by Threat Actors

Once threat actors are aware of the financial strain experienced by Yahoo, this signals a weakened investment on implementing security controls, potentially intensifying the attacks. In

the height of settlements and shareholder lawsuits, threat actors can also locate dissatisfied parties and take advantage of them through spear-phishing or financial frauds.

Exploitation Example

Attackers could utilize news of financial losses to create spear-phishing emails that appear as legitimate from lawyers, regulators, or shareholders who request private communications or payments while the company is in financial distress.

Recommendations for Mitigation

The organization should promptly disclose financial and breach related information to maintain stakeholder trust. They should also improve internal financial controls to identify social engineering attempts targeting their finance department. An incident response plan should be in effect for periods of public crisis and financial instability.

Marketing and Advertising Campaigns

There is evidence reporting on Yahoo's marketing which involves using mediums such as TV, radio, online, and cinema, often focusing on personalization and user engagement (e.g., "Do You Yahoo?" and campaigns highlighting user-generated content or promotions like partnership giveaways.) Their messaging is brand positive, community-focused, and global (Baker, 2006; CNET, 2006).

Malicious Use by Threat Actors

Attackers can exploit knowledge of ongoing campaigns by deceiving users into believing fraudulent ads or websites are legitimate brand promotions.

Exploitation Example

Threat actors could create a phishing site that mimics the official Yahoo promotion campaign and collect user credentials disguising it as a contest entry or exclusive offer.

Recommendations for Mitigation

The organization should officially announce campaigns through verified channels. They could also work with ad partners and social platforms to monitor any fake campaigns and redirect suspicious domains. Lastly, offer a way for users or educate them on verifying campaigns legitimately online.

Partnerships and Collaborations

In order to improve ad delivery, user experience, and transparency, Yahoo works with significant media and technology partners (such as BuzzFeed, Roku, Jounce, Peer39, and Scope3). Additionally, strategic partnerships concentrate on content syndication and next-generation consumer experiences, including advanced analytics, CTV supply, and XR and AR content (Mitchell, 2025; Yahoo Inc, 2024).

Malicious Use by Threat Actors

With knowledge of information on partnerships, threat actors might use it to create targeted B2B phishing or business email compromise (BEC) operations. BEC is a form of phishing where attackers impersonate trusted individuals or organizations via email to trick victims into transferring funds, sharing sensitive data, or making fraudulent purchases (FBI, n.d.).

Exploitation Example

A BEC attack could be launched by threat actors by sending emails, from BuzzFeed's or Roku's executive team, asking Yahoo employees for sensitive information or access to systems as part of a collaborative project activity.

Recommendations for Mitigation

The organization should employ strict communication channels (e.g., out-of-band verification, digital signatures). Out-of-band verification is a security method (often used by financial institutions and organizations that function with strict security controls) that uses a separate communication channel to verify a user's identity, in addition to the primary channel used for the initial login (Barney, 2024; KZero Staff, 2023; OneSpan, n.d.; Regions, 2025).

Employees should be regularly informed about current legitimate partnerships and warn against sharing sensitive information without secondary verification. Limit information about partnership operational details unless necessary.

Recent News Coverage (Press Releases, Articles, Interviews)

The latest news on Yahoo focuses on partnerships that are growing their news, entertainment, and advertising services, as well as continuous advancements and relevance in digital media. The impact and consequences of Yahoo's large breaches from 2013 to 2014 are also reviewed, including the extent of user account compromise, legal repercussions, and the measures to restore the company's reputation and security posture (Perlroth, 2017; StrongDM Team, 2025; Wikipedia Contributors, 2024).

Malicious Use by Threat Actors

Threat actors may use news and breach details in phishing emails to induce panic (“Your account was exposed in the Yahoo breaches – update your password here”). Moreover, public news like platform changes can be exploited to legitimize fraudulent communications demanding action from users.

Exploitation Example

An attacker could email Yahoo users by mimicking customer support: “Due to new security control taking effect and recent platform changes, please re-enter your login information now to secure your account.”

Recommendations for Mitigation

The organization should communicate with users about official breach response protocols and offer clear guidance on avoiding fraud. Instead of only using email to communicate with users, incorporate banner messages and in-app notifications for security alerts. Lastly, increase external threat monitoring during periods of media attention on breaches or company transitions.

References

- CBM Team. (2025, July 12). *What Are Yahoo's Mission, Vision, and Core Values?* CANVAS, SWOT, PESTEL & BCG Matrix Editable Templates for Startups; CanvasBusinessModel. <https://canvasbusinessmodel.com/blogs/mission/yahoo-mission>
- Achterholt, A. (2025, February 6). *Cybersecurity: Protect your Crown Jewels*. Wwww.adnovum.com. <https://www.adnovum.com/blog/cybersecurity-protect-your-crown-jewels>
- Allstate Identity Protection. (2016). *InfoArmor: Yahoo Data Breach Investigation* | Allstate Identity Protection. Allstateidentityprotection.com. <https://www.allstateidentityprotection.com/business/content-hub/infoarmor-yahoo-data-breach-investigation>
- Bagla, K. (2024, November 14). *ISACA Now Blog 2024 A Simplified Approach to Cost Effectively Boost Security Around Digital Crown Jewels*. ISACA. <https://www.isaca.org/resources/news-and-trends/isaca-now-blog/2024/a-simplified-approach-to-cost-effectively-boost-security-around-digital-crown-jewels>
- Baker, L. (2006, September 18). *Yahoo's Massive Marketing Campaign*. Search Engine Journal. <https://www.searchenginejournal.com/yahoos-massive-marketing-campaign/3802/>
- Barney, N. (2024, May 15). *What is out-of-band authentication?* | Definition from TechTarget. TechTarget. <https://www.techtarget.com/searchsecurity/definition/out-of-band-authentication>

Blassberger, K., Solomon, M., Marcogliese, P., & Mukhi, R. (2018, May 17). *Failure to Disclose a Cybersecurity Breach*. The Harvard Law School Forum on Corporate Governance.

<https://corpgov.law.harvard.edu/2018/05/17/failure-to-disclose-a-cybersecurity-breach/>

CBS San Francisco. (2015, April 22). *Yahoo Revival Not Evident In Latest Earnings Report; Value Beyond Asian Holdings Questioned*. Cbsnews.com.

<https://www.cbsnews.com/sanfrancisco/news/yahoo-revival-not-evident-in-latest-earnings-report-value-beyond-asian-investments-questioned/>

CNET. (2006, September 18). *Yahoo yodels for new ads*. CNET. <https://www.cnet.com/tech/tech-industry/yahoo-yodels-for-new-ads/>

Faulder, C. (2023, October 24). *In a world of deep fakes, securing an organization's crown jewels gets real*. ERP Today. <https://erp.today/in-a-world-of-deep-fakes-securing-an-organizations-crown-jewels-gets-real/>

FBI. (n.d.). *Business Email Compromise*. FBI. Retrieved July 20, 2025, from <https://www.fbi.gov/how-we-can-help-you/scams-and-safety/common-frauds-and-scams/business-email-compromise>

Francisco, T. (2022). *Protecting the crown jewels from cyberattack*. PwC. <https://www.pwc.com/ph/en/tax/tax-publications/taxwise-or-otherwise/2022/protecting-the-crown-jewels-from-cyberattack.html>

JLP. (2005, April 25). *Man on a Mission: Yahoo's (YHOO) Mission Statement & Values*. ManonaMission. <https://manonamission.blogspot.com/2005/04/yahoos-yhoo-mission-statement-values.html>

KZero Staff. (2023, October 17). *Out-of-band authentication - Kelvin Zero*. Kelvin Zero.

<https://kzero.com/resources/glossary/out-of-band-authentication-definition/>

Logixal. (2016). *The Biggest Cybersecurity Heist of All Time: A Caper for the Ages!* Logixal.

https://www.logixal.co.uk/insights/the-biggest-cybersecurity-heist-of-all-time-a-caper-for-the-ages?_nodeTranslation=319

Luckie, S. (2023, October 5). *Cyber Awareness Month: Crown Jewels | What are your valuable digital assets?* WeAreTechWomen - Supporting Women in Technology.

<https://wearetechwomen.com/cyber-awareness-month-crown-jewels-what-are-your-valuable-digital-assets/>

Mile High Cyber. (2025, June 18). *Protecting the Crown Jewels: The Heart of Effective*

Cybersecurity. Mile High Cyber. <https://www.milehighcyber.com/blog/protecting-the-crown-jewels-the-heart-of-effective-cybersecurity>

Mills, E. (2006, April 18). *Yahoo earnings down from a year ago but in line with expectations*.

CNET. <https://www.cnet.com/culture/yahoo-earnings-down-from-a-year-ago-but-in-line-with-expectations/>

Mitchell, S. (2025, January 8). *Yahoo DSP announces partnerships to boost ad capabilities*.

ECommerceNews India. <https://ecommercenews.in/story/yahoo-dsp-announces-partnerships-to-boost-ad-capabilities>

Morgan Hill. (2022). *Protecting Your Crown Jewels: The Power of ISO 27001*. Morgan Hill.

<https://www.morganhillcg.com/blog/item/protecting-your-crown-jewels-the-power-of-iso-27001>

OneSpan. (n.d.). *What is Out-of-Band Authentication?* | OneSpan. [Www.onespan.com](https://www.onespan.com).

<https://www.onespan.com/topics/out-of-band-authentication>

OwlEye. (2024, June 20). *In today's digital age, certain applications within an organization are so vital that they are often referred to as "Crown Jewels."* [Linkedin.com](https://www.linkedin.com/pulse/protecting-your-crown-jewels-critical-importance-cybersecurity-awxxc/).

<https://www.linkedin.com/pulse/protecting-your-crown-jewels-critical-importance-cybersecurity-awxxc/>

Perlroth, N. (2017, October 3). All 3 Billion Yahoo Accounts Were Affected by 2013 Attack. *The New York Times*. <https://www.nytimes.com/2017/10/03/technology/yahoo-hack-3-billion-users.html>

Regions. (2025). *What Is Out-of-Band Technology & Ooba?* | Regions Bank. [RegionsBank](https://www.regions.com/help/online-banking-help/login-and-security/out-of-band-authentication/what-is-out-of-band-technology-and-ooba-authentication).

<https://www.regions.com/help/online-banking-help/login-and-security/out-of-band-authentication/what-is-out-of-band-technology-and-ooba-authentication>

Ribeiro, A., Ginter, A., Gunter, D., Lota, S., McPhee, A., Hunter, J., & Ribeiro, Andrew, A.

(2024, October 20). *Bridging IT/OT divide by developing risk management approach to safeguard organizational crown jewels*. Industrial Cyber.

<https://industrialcyber.co/features/bridging-it-ot-divide-by-developing-risk-management-approach-to-safeguard-organizational-crown-jewels/>

Singh, A. (2020, October 27). *A Key Cyber Incident Response Step - Identify your Crown Jewels*.

[Www.cm-Alliance.com](https://www.cm-alliance.com/cybersecurity-blog/a-key-cyber-incident-response-step-identify-your-crown-jewels). <https://www.cm-alliance.com/cybersecurity-blog/a-key-cyber-incident-response-step-identify-your-crown-jewels>

StrongDM Team. (2025, March 18). *Yahoo Data Breach: What Happened and How to Prevent It*.

[Strongdm.com](https://www.strongdm.com/what-is/yahoo-data-breach); StrongDM, Inc. <https://www.strongdm.com/what-is/yahoo-data-breach>

Trend Micro. (2016, December 15). *Yahoo Discloses 2013 Breach that Exposed Over One Billion Accounts* | Trend Micro (AE). Trendmicro.com.

<https://www.trendmicro.com/vinfo/ae/security/news/cyber-attacks/yahoo-discloses-2013-breach-exposed-over-1billion-accounts>

Truță, F. (2017, October 4). *New investigation into Yahoo 2013 data breach reveals that all 3 billion user accounts were compromised*. Hot for Security.

<https://www.bitdefender.com/en-us/blog/hotforsecurity/new-investigation-into-yahoo-2013-data-breach-reveals-that-all-3-billion-user-accounts-were-compromised>

Wikipedia Contributors. (2024, August 29). *Yahoo data breaches*. Wikipedia; Wikimedia Foundation. https://en.wikipedia.org/wiki/Yahoo_data_breaches

Yahoo Inc. (2024, November 17). *Yahoo & BuzzFeed Expand Strategic Partnership Across Programmatic, Identity and Content to Innovate Consumer Experiences*. Yahooinc.com; Yahoo Inc. <https://www.yahooinc.com/press/yahoo-buzzfeed-expand-strategic-partnership>

Part B: Phishing Email Exercise

Phishing Email Example

Subject: Upcoming Changes to Secure Policy and Information Systems

From: IT Department <itdeparment@company.com>

Dear Finance Team,

I hope this email finds you well.

We would like to inform you of upcoming changes to the company's security policy and info systems infrastructure, which are part of a big effort to strengthen data protection, improve compliance, and streamline access control across departments.

To help you with this transition, a mandatory short training course will be assigned to all team members. The course is designed to help you understand the changes, their implications for your daily work, and how to adopt the updated protocols effectively.

We encourage you to login in with your company credentials as all employees have already been registered on the platform. Your cooperation and timely participation are essential to ensuring a smooth implementation of these updates. If you have any questions or concerns, please do not hesitate to reach out.

Thank you for your attention and support.

Please see attached a link to the aforementioned course.

www.courseraa.org/security-policies-in-organisations-gwibu/learn/it-secure

Best regards,

IT Department

If you believe this email was sent in error or may be suspicious, please report it to IT Security here: [Report This Email](#)

Names and Titles of Target(s)

This email is addressed to the Finance Team, which indicated that the Finance Department is the specific target. No individual names are used, which is common in broad phishing attempts that aim to reach multiple users within a high-value department.

Type of Phishing Attack

This type of attack is spear phishing. While not directed individually, this email targets a specific department (Finance) and imitates a trusted source (IT Department). The goal is to trick employees into clicking the malicious link and entering their login credentials.

Likely Crown Jewels Attackers Are After

Given that the Finance Department is targeted, the attackers are likely after:

- Financial Records and Reports (budgets, forecasts, ledgers)
- Payroll and Banking Information
- Credentials to Financial System (Enterprise Resource Planning, banking portals)
- Invoices, Tax Filings, and Vendor Payment Data

These crown jewels can be monetized directly or used potentially in follow-up attacks like wire fraud or business email compromise (BEC).

Social Engineering Tactics Used

Authority Impersonation (Purple)

The sender uses an email signature (IT Department) for impersonation. Employees are more likely to comply when they believe the request comes from a trusted, high-authority source within the organization.

Urgency and Obligation (Blue)

In the email, words like “mandatory short training course” pressure the recipient into fast action, reducing the chances of them verifying the source. The email also implies that it is a corporate-wide change which adds pressure.

Exploitation of Trust in Internal Processes (Orange)

Most companies regularly roll out policy updates and require training, so the email’s content seems familiar and plausible.

Link Obfuscation (Red)

The link (www.courseraa.org/...) mimics Coursera, a well-known course platform, but is subtly misspelled and includes a suspicious sub path. This exploits user inattention and trust in recognizable brand names. To conclude, the last line in the email is intended to be actually malicious. It disguises itself as a legitimate link for IT support services. This is a reminder that threat actors can be creative and if not investigated closely can be missed entirely.